

**БУЗОО \”МИАЦ\”**

**ПОЛИТИКА ИНФОРМАЦИОННОЙ  
БЕЗОПАСНОСТИ**

**Политика информационной  
безопасности БУЗОО  
\”МИАЦ\”**

Объект защиты: Информационная система персональных данных (ИСПДн)

Категория: Персональные данные (ПДн)

СОГЛАСОВАНО:

Руководитель службы ИБ

«\_\_\_\_\_» \_\_\_\_\_ 20\_\_\_\_ г.

г. Омск, 2026

# Содержание

|          |                                                  |          |
|----------|--------------------------------------------------|----------|
| <b>1</b> | <b>Требования</b>                                | <b>3</b> |
| 1.1      | Технические меры безопасности . . . . .          | 3        |
| 1.2      | Аутентификация и авторизация . . . . .           | 3        |
| 1.3      | Управление доступом . . . . .                    | 4        |
| 1.4      | Журналирование и мониторинг событий . . . . .    | 4        |
| <b>2</b> | <b>Ответственность</b>                           | <b>5</b> |
| 2.1      | Общие положения . . . . .                        | 5        |
| 2.2      | Организация обучения . . . . .                   | 5        |
| 2.3      | Мониторинг и анализ . . . . .                    | 5        |
| 2.4      | Обеспечение конфиденциальности . . . . .         | 5        |
| 2.5      | Обеспечение целостности данных . . . . .         | 6        |
| 2.6      | Обеспечение доступности . . . . .                | 6        |
| <b>3</b> | <b>Контроль</b>                                  | <b>6</b> |
| 3.1      | Мониторинг информационной безопасности . . . . . | 6        |
| 3.2      | Проверка соответствия . . . . .                  | 6        |
| 3.3      | Тестирование защиты . . . . .                    | 7        |
| 3.4      | Обучение персонала . . . . .                     | 7        |
| 3.5      | Журналирование событий . . . . .                 | 7        |
| 3.6      | Анализ угроз . . . . .                           | 7        |
| 3.7      | Внедрение технических средств . . . . .          | 7        |
| 3.8      | Оценка эффективности . . . . .                   | 8        |
| 3.9      | Контроль доступа . . . . .                       | 8        |
| 3.10     | Аудит . . . . .                                  | 8        |
| 3.11     | Обеспечение конфиденциальности . . . . .         | 8        |
| 3.12     | Мониторинг сетевых активностей . . . . .         | 8        |
| 3.13     | Обеспечение целостности данных . . . . .         | 9        |
| <b>4</b> | <b>Заключ</b>                                    | <b>9</b> |
| 4.1      | Технические меры безопасности . . . . .          | 9        |
| 4.2      | Организационные мероприятия . . . . .            | 9        |

|                           |                                                              |           |
|---------------------------|--------------------------------------------------------------|-----------|
| 4.3                       | Управление доступами . . . . .                               | 9         |
| 4.4                       | Журналирование и аудит . . . . .                             | 10        |
| 4.5                       | Обеспечение конфиденциальности . . . . .                     | 10        |
| 4.6                       | Меры защиты при кризисных ситуациях . . . . .                | 10        |
| 4.7                       | Обучение и повышение квалификации . . . . .                  | 10        |
| 4.8                       | Мониторинг и анализ событий . . . . .                        | 11        |
| 4.9                       | Обеспечение доступности информации . . . . .                 | 11        |
| 4.10                      | Обеспечение конфиденциальности персональных данных . . . . . | 11        |
| 4.11                      | Обеспечение безопасности при работе удаленно . . . . .       | 11        |
| <b>Нормативные ссылки</b> |                                                              | <b>13</b> |

# 1. Требования

## 1.1. Технические меры безопасности

Обязуется обеспечить наличие устойчивой инфраструктуры информационной безопасности, включающей средства защиты информации согласно требованиям ФСТЭК России №239. Необходимо внедрить системы обнаружения вторжений (IDS) и управления событиями безопасности (SIEM), что позволяет выявлять аномалии в работе информационных систем и предотвращать несанкционированный доступ к данным.

Должно быть обеспечено использование шифрования для защиты конфиденциальных данных, передаваемых через интернет. В частности, обязательным является применение протокола TLS версии 1.2 или выше для передачи информации в открытой сети. Подлежит выполнению техническое обеспечение шифрования ключами с длиной не менее 256 бит.

Организация обеспечивает реализацию межсетевых экранов и брандмауэров, соответствующих требованиям ФСТЭК России. Эти средства позволяют ограничивать доступ к ресурсам информационных систем только для авторизованных пользователей в соответствии с их правами доступа.

## 1.2. Аутентификация и авторизация

Приказ Минздрава РФ №956н от 18 октября 2017 года определяет требования к аутентификации пользователей. Необходимо внедрить двухфакторную аутентификацию (2FA) для всех сотрудников, имеющих доступ к медицинским данным пациентов.

Должно быть организовано автоматическое отключение сессий пользователей при длительном бездействии в соответствии с требованиями 152-ФЗ. Процедура предусматривает разблокировку системы только после успешной аутентификации пользователя, что снижает риск несанкционированного доступа.

Организация обеспечивает внедрение систем управления паролями, которые ограничивают использование слабых паролей и требуют регулярную смену авторизационных данных. Система должна предупреждать пользователей при нарушении правил безопасности, например, если пароль введен неверно более трёх

раз подряд.

### **1.3. Управление доступом**

Необходимо внедрить стратегию управления доступами (IAM), согласованную с Положением о порядке обработки персональных данных Министерства здравоохранения РФ. Это обеспечивает, что каждый пользователь имеет право на получение только той информации, которая необходима для его профессиональной деятельности.

Производится проверка всех прав доступа не менее одного раза в год, включая проверку уровня доступа к персональным данным пациентов согласно Приказу Минздрава РФ №956н. Это позволяет своевременно корректировать права доступа и обеспечивает надлежащий уровень защиты информации.

Организация обязуется организовать индивидуальное управление доступами для каждого сотрудника, что гарантирует соблюдение принципа минимальных прав доступа — предоставления пользователю только тех возможностей, которые необходимы для выполнения его работы.

### **1.4. Журналирование и мониторинг событий**

Требуется организовать систематическое журналирование всех операций в информационной среде организации. В частности, должны фиксироваться все попытки доступа к данным пациента, а также любые изменения, произведённые с этими данными.

Осуществляется мониторинг журналов безопасности для выявления возможных нарушений или угроз информационной безопасности. В случае обнаружения подозрительной активности необходимо немедленно провести анализ и принять соответствующие действия, направленные на ликвидацию угрозы.

Организация обязуется обеспечивать сохранность журналов не менее 1 года согласно требованиям ФСТЭК России №239. Это позволяет в случае необходимости восстановить информацию о событиях, произошедших ранее, и провести расследование при возникновении инцидентов.

## **2. Ответственность**

### **2.1. Общие положения**

Обязуется обеспечить наличие должностных лиц, ответственных за информационную безопасность (ИБ) организации. В соответствии с требованиями ФСТЭК России и 152-ФЗ, необходимо организовать структуру управления ИБ таким образом, чтобы каждый сотрудник понимал свои обязанности в рамках обеспечения безопасности информации [152-ФЗ, ст. 19]. Должно быть обеспечено наличие должностных инструкций для всех сотрудников, ответственных за различные аспекты информационной безопасности.

### **2.2. Организация обучения**

Необходимо внедрить систему регулярного обучения персонала по вопросам информационной безопасности. В частности, обучение должно включать актуализацию знаний о методах защиты информации и мерах предотвращения утечек данных [ФСТЭК России №239, раздел 5]. Процедура предусматривает проведение тренингов по вопросам кибербезопасности для всех сотрудников не реже одного раза в год.

### **2.3. Мониторинг и анализ**

Осуществляется мониторинг за соблюдением требований информационной безопасности. В частности, подлежит выполнению регулярный анализ журналов событий системы безопасности с целью выявления нарушений [ФСТЭК России №239, раздел 5]. Является обязательным проведение расследования всех инцидентов информационной безопасности в соответствии с установленными процедурами.

### **2.4. Обеспечение конфиденциальности**

Запрещается передавать информацию третьим лицам без соответствующего согласия и наличия необходимых разрешений. В частности, необходимо организовать систему контроля доступа к конфиденциальной информации с использо-

ванием современных методов шифрования [152-ФЗ, ст. 19]. Процедурные меры включают регулярную проверку эффективности применяемых средств защиты.

## **2.5. Обеспечение целостности данных**

Требуется организовать систему контроля изменений информации с целью предотвращения несанкционированного доступа и модификации данных. В частности, система должна предусматривать использование цифровых подписей для подтверждения целостности передаваемой информации [ФСТЭК России №239, раздел 5]. Должно быть обеспечено наличие процедур по восстановлению данных в случае их повреждения или утраты.

## **2.6. Обеспечение доступности**

Обязуется организовать резервное копирование всех важных данных организации. В частности, необходимо проводить регулярные проверки работоспособности системы резервного копирования [ФСТЭК России №239, раздел 5]. Процедурные меры включают проведение тестов восстановления данных для подтверждения их доступности в случае аварийных ситуаций.

# **3. Контроль**

## **3.1. Мониторинг информационной безопасности**

Требуется организовать систему мониторинга ИБ, включающую средства сбора и анализа событий системы (SIEM). Должно быть обеспечено непрерывное наблюдение за состоянием информационных ресурсов организации. Процедурой предусматривается регулярный анализ журналов событий для выявления подозрительной активности.

## **3.2. Проверка соответствия**

Необходимо внедрить процедуры проверки соответствия системы информационной безопасности требованиям ФСТЭК России и 152-ФЗ. Производится

анализ конфигураций систем, оборудования и программного обеспечения на соответствие установленным стандартам.

### **3.3. Тестирование защиты**

Обязуется обеспечить проведение регулярных тестов системы защиты информации с целью выявления уязвимостей и оценки эффективности применяемых мер по защите данных. В частности, следует проводить аудит на соответствие требованиям ФСТЭК России №239.

### **3.4. Обучение персонала**

Организация обязана организовать обучение сотрудников вопросам информационной безопасности в соответствии с требованиями Приказа Минздрава РФ №956н от 10.11.2017 г. Процедурой предусматривается проведение тренингов и семинаров для повышения уровня квалификации персонала.

### **3.5. Журналирование событий**

Должно быть обеспечено ведение журналов информационной безопасности, содержащих записи о всех операциях с информацией, а также об изменениях конфигураций систем и сетевых устройств. В соответствии с требованиями ФСТЭК России, журналы должны храниться не менее 3 лет.

### **3.6. Анализ угроз**

Осуществляется анализ потенциальных угроз информационной безопасности организации для разработки мер по их предотвращению и снижению рисков. Процедурой предусматривается регулярное обновление анализа угроз с учетом изменений в окружающей среде.

### **3.7. Внедрение технических средств**

Требуется организовать внедрение технических средств защиты информации, таких как шифрование данных (AES), системы мониторинга и предотвра-



щения вторжений (IDS/IPS). Подлежит выполнению регулярное обновление программного обеспечения для защиты от новых угроз.

### **3.8. Оценка эффективности**

Производится оценка эффективности применяемых мер по информационной безопасности с целью их дальнейшего совершенствования. В частности, следует проводить анализ результатов тестирования и мониторинга для выявления слабых мест в системе защиты.

### **3.9. Контроль доступа**

Необходимо организовать контроль доступа к информационным ресурсам организации с учетом требований ФСТЭК России №21. Процедурой предусматривается регулярное обновление списков пользователей и прав доступа.

### **3.10. Аудит**

Осуществляется аудит информационной безопасности организации с целью выявления несоответствий требованиям ФСТЭК России и 152-ФЗ. Процедурой предусматривается проведение внутренних проверок на регулярной основе.

### **3.11. Обеспечение конфиденциальности**

Должно быть обеспечено соблюдение требований по защите персональных данных, установленных Приказом Министерства здравоохранения РФ №956н от 10.11.2017 г. Процедурой предусматривается регулярное обучение сотрудников вопросам конфиденциальности и защиты данных.

### **3.12. Мониторинг сетевых активностей**

Требуется организовать мониторинг сетевых активностей для выявления подозрительных действий. Процедурой предусматривается использование средств сетевого мониторинга и анализа трафика (например, IDS/IPS).

### 3.13. Обеспечение целостности данных

Обязуется обеспечить защиту данных от несанкционированного изменения или уничтожения информации.

## 4. Заключение

### 4.1. Технические меры безопасности

Должно быть обеспечено использование современных средств защиты информации для предотвращения несанкционированного доступа к данным. Обязуется внедрить системы шифрования данных, соответствующие требованиям ФСТЭК России и 152-ФЗ, в частности алгоритмы шифрования AES и TLS. В соответствии с [ФСТЭК №239, раздел 5], необходимо организовать меры по защите информации при передаче через сети Интернет, что может быть достигнуто путем применения протоколов SSL/TLS.

### 4.2. Организационные мероприятия

Организация обязуется регулярно проводить аудит информационных систем и инфраструктуры для выявления уязвимостей. Процедурой предусматривается проведение внутренних проверок на соответствие требованиям безопасности не реже одного раза в год, с учетом рекомендаций ФСТЭК России. Кроме того, необходимо организовать обучение персонала по вопросам информационной безопасности и мерам защиты данных пациентов.

### 4.3. Управление доступами

Необходимо внедрить строгую систему управления доступами к информации, включающую принципы минимальных полномочий и многофакторную аутентификацию. Система должна обеспечивать контроль за действиями пользователей и фиксировать все изменения в правах доступа. В соответствии с [152-ФЗ, ст. 19], организация обязана осуществлять мониторинг действий пользователей для предотвращения несанкционированного доступа к конфиденциальной информа-

ции.

#### **4.4. Журналирование и аудит**

Требуется организовать журналы событий информационных систем, которые должны содержать полную информацию о действиях пользователей и изменениях в данных. Процедурой предусматривается регулярное проведение анализа журнальных записей для выявления подозрительной активности. В соответствии с [ФСТЭК №239, раздел 5], журналы событий должны храниться в защищенном режиме и быть доступны только авторизованным сотрудникам.

#### **4.5. Обеспечение конфиденциальности**

Организация обязуется обеспечить защиту персональных данных пациентов от несанкционированного доступа, утраты или уничтожения. В частности, необходимо организовать меры по шифрованию баз данных с использованием современных алгоритмов шифрования. Кроме того, следует обеспечить контроль за передачей персональных данных пациентов третьим лицам в соответствии с требованиями 152-ФЗ.

#### **4.6. Меры защиты при кризисных ситуациях**

Подлежит выполнению разработка и внедрение плана действий по устранению последствий инцидентов информационной безопасности. В частности, необходимо организовать резервное копирование данных с регулярным проведением проверки работоспособности системы восстановления информации. Кроме того, следует обеспечить наличие аварийного режима работы систем для минимизации влияния инцидентов на работу организации.

#### **4.7. Обучение и повышение квалификации**

Организация обязуется регулярно проводить обучение сотрудников по вопросам информационной безопасности. В частности, необходимо организовать тренинги по выявлению фишинговых атак и другим методам защиты от внешних

угроз. Кроме того, следует обеспечить доступ к актуальной информации о новых уязвимостях и способах их эксплуатации.

#### **4.8. Мониторинг и анализ событий**

Осуществляется мониторинг информационных систем с использованием средств SIEM для выявления подозрительной активности. Процедурой предусматривается регулярное проведение анализа данных, собранных системами мониторинга, для своевременного реагирования на угрозы информационной безопасности.

#### **4.9. Обеспечение доступности информации**

Организация обязуется обеспечить надежность и доступность информационных ресурсов. В частности, необходимо организовать резервное копирование данных с регулярным проведением проверки работоспособности системы восстановления информации. Кроме того, следует обеспечить наличие аварийного режима работы систем для минимизации влияния инцидентов на работу организации.

#### **4.10. Обеспечение конфиденциальности персональных данных**

Организация обязуется обеспечивать защиту персональных данных пациентов от несанкционированного доступа, утраты или уничтожения. В частности, необходимо организовать меры по шифрованию баз данных с использованием современных алгоритмов шифрования. Кроме того, следует обеспечить контроль за передачей персональных данных пациентов третьим лицам в соответствии с требованиями 152-ФЗ.

#### **4.11. Обеспечение безопасности при работе удаленно**

Необходимо внедрить меры по обеспечению информационной безопасности при работе сотрудников из домашних офисов. В частности, следует организовать использование защищенных каналов связи для передачи данных и обеспе-

чение контроля доступа к ресурсам организации с использованием виртуальных частных сетей (VPN).

## **Нормативные ссылки**

- Федеральный закон №152-ФЗ от 27.07.2006 «О персональных данных»
- Приказ ФСТЭК России №21 от 18.02.2013 «Об утверждении Составы и содержания организационных и технических мер по обеспечению безопасности персональных данных»